HỆ THỐNG NỀN TẢNG VEGGIELIFE
Ban Pháp chế & An toàn Ẩm thực Chay
Mã văn bản: SỐ 02/2026/VGL-PDPD

CỘNG HÒA XÃ HỘI CHỦ NGHĨA VIỆT NAM
Độc lập – Tự do – Hạnh phúc
TP. Hồ Chí Minh, ngày 30 tháng 10 năm 2026

CHÍNH SÁCH BẢO MẬT VÀ BẢO VỆ DỮ LIỆU CÁ NHÂN

(PRIVACY POLICY & SENSITIVE HEALTH DATA PROTECTION)
Ban hành tuân thủ Nghị định số 13/2023/NĐ-CP về Bảo vệ dữ liệu cá nhân của Chính phủ Việt Nam

□□ THÔNG BÁO XỬ LÝ DỮ LIỆU CÁ NHÂN THEO NGHỊ ĐỊNH 13/2023/NĐ-CP: VeggieLife cam kết bảo vệ dữ liệu cá nhân và Dữ liệu sức khỏe nhạy cảm của bạn bằng các biện pháp an ninh mạng nghiêm ngặt nhất. Bằng việc đăng ký tài khoản, bạn xác nhận đã được thông báo, hiểu rõ và đồng ý cho phép VeggieLife xử lý dữ liệu cá nhân của bạn theo đúng mục đích, phạm vi và quyền hạn được quy định tại bản Chính sách này.

Điều 1. Căn cứ pháp lý và Nguyên tắc bảo vệ dữ liệu

1.1. Căn cứ pháp lý: Chính sách này được xây dựng trên cơ sở tuân thủ nghiêm túc các văn bản quy phạm pháp luật hiện hành của Nước CHXHCN Việt Nam: (1) Nghị định số 13/2023/NĐ-CP ngày 17/04/2023 về Bảo vệ dữ liệu cá nhân (PDPD); (2) Luật An toàn thông tin mạng số 86/2015/QH13; (3) Luật Công nghệ thông tin số 67/2006/QH11; và (4) Luật Giao dịch điện tử số 20/2023/QH15.

1.2. Các nguyên tắc xử lý dữ liệu bất biến:

- Nguyên tắc hợp pháp & minh bạch: Mọi hoạt động thu thập dữ liệu đều có thông báo trước và có sự đồng thuận rõ ràng của chủ thể dữ liệu.
- Nguyên tắc giới hạn mục đích: Dữ liệu chỉ được sử dụng cho mục đích cá nhân hóa dinh dưỡng chay và vận hành hệ thống, tuyệt đối không phục vụ mục đích thương mại ngoài phạm vi cam kết.
- Nguyên tắc toàn vẹn và bảo mật (Confidentiality & Integrity): Áp dụng các tiêu chuẩn mã hóa hiện đại trong lưu trữ và truyền tải dữ liệu.

Điều 2. Phân loại Dữ liệu cá nhân thu thập

Hệ thống phân định rõ ràng 02 nhóm dữ liệu theo quy định của Nghị định 13/2023/NĐ-CP:

2.1. Dữ liệu cá nhân cơ bản:

- Họ và tên hiển thị của người dùng (Full Name);
- Địa chỉ thư điện tử xác thực (Email Address);
- Mật khẩu đăng nhập (chỉ lưu trữ dưới dạng băm một chiều an toàn qua BCrypt cost 12);
- Ảnh đại diện (Avatar) và ảnh chụp công thức người dùng tải lên;
- Dữ liệu kỹ thuật nhật ký: Địa chỉ IP, chuỗi định danh User-Agent, nhật ký đăng nhập nhằm ngăn chặn tấn công spam.

2.2. DỮ LIỆU CÁ NHÂN NHẠY CẢM VỀ SỨC KHỎE (Quy định tại Khoản 4 Điều 2 Nghị định 13/2023/NĐ-CP & Tiêu chuẩn PRV-1):

- Chỉ số nhân trắc học: Chiều cao, cân nặng, độ tuổi, giới tính sinh học;
- Chỉ số sức khỏe tính toán: Chỉ số khối cơ thể (BMI theo chuẩn WHO dành cho người Tây Thái Bình Dương WPRO), tỷ lệ tiêu hao năng lượng cơ bản (BMR), và tổng năng lượng tiêu thụ hàng ngày (TDEE);
- Trường phái ăn chay khai báo: Lựa chọn duy nhất trong 07 trường phái (Vegan, Lacto, Ovo, Lacto-Ovo, Buddhist, Pollotarian, Pescatarian);
- Danh sách đen dị ứng thực phẩm (Allergies Blacklist): Các dị nguyên gây phản ứng dị ứng nghiêm trọng được người dùng tích chọn (Đậu nành, Gluten lúa mì, Đậu phộng, Quả hạch/Hạt cây, Mè, v.v.).

Điều 3. Mục đích và Phạm vi sử dụng dữ liệu

Dữ liệu thu thập được sử dụng giới hạn trong các nghiệp vụ sau:

3.1. Cá nhân hóa thuật toán AI dinh dưỡng: Thuật toán AI kết hợp trường phái ăn chay và danh sách đen dị ứng làm ràng buộc cứng (Hard Constraints) để lập kế hoạch thực đơn tuần, bảo đảm tuyệt đối không gợi ý món ăn có thành phần gây dị ứng cho người dùng.

3.2. Quản lý kho thực phẩm Tủ lạnh thông minh: Lưu trữ danh sách nguyên liệu bạn sở hữu từ tính năng quét ảnh hoặc nhập tay để gợi ý công thức chế biến tận dụng thực phẩm tránh hư hao lãng phí.

3.3. Xác thực an toàn và kiểm toán an ninh: Gửi mã OTP xác minh, xoay vòng Access Token (15 phút) và Refresh Token trên Redis (SEC-2), phát hiện và ngăn chặn các hành vi gian lận.

3.4. Thống kê nghiên cứu ẩn danh (PRV-2): Các báo cáo thống kê dành cho Quản trị viên chỉ được phép hiển thị dữ liệu tổng hợp theo ngày với độ trễ tối đa 24 giờ và tuyệt đối không đính kèm thông tin định danh cá nhân.

Điều 4. Cơ chế bảo vệ đặc biệt đối với Dữ liệu sức khỏe nhạy cảm (PRV-1)

 CAM KẾT BẢO VỆ DỮ LIỆU SỨC KHỎE: QUY ĐỊNH BẢO VỆ DỮ LIỆU SỨC KHỎE (TIÊU CHUẨN PRV-1): Dữ liệu sức khỏe (chiều cao, cân nặng, BMI, BMR, TDEE, tiền sử dị ứng thực phẩm) là dữ liệu cá nhân đặc biệt nhạy cảm. Chỉ có chủ sở hữu tài khoản và thuật toán hệ thống được quyền đọc dữ liệu này. Quản trị viên (Admin) chỉ được phép tra cứu trong trường hợp xử lý khiếu nại hoặc điều tra vi phạm an toàn; mọi hành vi xem dữ liệu sức khỏe của Admin bắt buộc phải được ghi nhận vào Nhật ký kiểm toán không thể xóa sửa (SEC-12).

4.1. Cam kết KHÔNG bán dữ liệu: VeggieLife cam kết tuyệt đối không bán, cho thuê, thương mại hóa hoặc chuyển giao dữ liệu sức khỏe của người dùng cho các hãng bảo hiểm, công ty dược phẩm hoặc mạng lưới quảng cáo của bên thứ ba dưới bất kỳ hình thức nào.

Điều 5. Quy chế xử lý dữ liệu hình ảnh (AI Vision - Quét tủ lạnh & Mã vạch)

5.1. Kiểm tra an toàn tệp tải lên (SEC-7): Mọi hình ảnh gửi lên hệ thống được kiểm tra tính hợp lệ bằng chữ ký tệp (magic bytes), giới hạn dung lượng ≤ 5 MB (tối đa 10 MB cho ảnh AI), định dạng hỗ trợ gồm JPEG, PNG, WEBP.

5.2. Tính bảo mật của hình ảnh: Ảnh chụp tủ lạnh và ảnh chụp bao bì mã vạch chỉ phục vụ mục đích trích xuất danh mục nguyên liệu thực phẩm và phân tích phụ gia thực phẩm E-numbers. Hình ảnh được xử lý trên phân vùng bộ nhớ an toàn và không bị công khai trên mạng xã hội cộng đồng.

Điều 6. Lưu trữ dữ liệu và Chính sách Ân hạn xóa tài khoản 30 ngày (CO-23)

6.1. Thời gian lưu trữ: Dữ liệu cá nhân được lưu trữ trong suốt thời gian tài khoản người dùng hoạt động trên hệ thống VeggieLife.

6.2. Cơ chế xóa tài khoản có ân hạn (Grace Period) theo Nghị định 13/2023/NĐ-CP:

- Khi người dùng gửi yêu cầu xóa tài khoản, hệ thống áp dụng thời gian ân hạn chính xác 30 ngày.
- Trong 30 ngày này, dữ liệu tài khoản bị tạm khóa truy cập công khai nhưng được giữ nguyên trạng thái; người dùng có thể đổi ý bằng cách đăng nhập lại để khôi phục tài khoản.
- Hết thời hạn 30 ngày: Hệ thống tự động kích hoạt quy trình xóa dữ liệu: toàn bộ họ tên, email, mật khẩu băm, ảnh đại diện và các chỉ số sức khỏe sẽ bị xóa sạch hoặc ẩn danh hóa vĩnh viễn (anonymized) trong cơ sở dữ liệu theo Tiêu chuẩn CO-23.

Điều 7. Các biện pháp bảo vệ kỹ thuật và An ninh thông tin

VeggieLife triển khai hệ thống an ninh phòng thủ đa lớp tuân thủ tiêu chuẩn quốc tế và OWASP Top 10:

- Mã hóa đường truyền: Toàn bộ kết nối giữa trình duyệt Frontend và máy chủ Backend bắt buộc chạy qua giao thức HTTPS mã hóa TLS 1.3.
- Bảo vệ phiên xác thực: Access Token JWT có thời hạn 15 phút; Refresh Token được lưu trữ trên bộ nhớ đệm Redis, có cơ chế xoay vòng (token rotation) và thu hồi toàn bộ phiên đăng nhập khi phát hiện dấu hiệu bất thường (SEC-2).
- Tiêu đề bảo mật HTTP (SEC-14): Thiết lập chính sách bảo mật nội dung chặt chẽ gồm Content-Security-Policy (CSP), X-Content-Type-Options: nosniff, X-Frame-Options: DENY nhằm ngăn chặn tấn công clickjacking và XSS.
- Chống tiêm lệnh AI Prompt Injection (SEC-15): Thiết lập ranh giới bảo vệ nghiêm ngặt giữa dữ liệu người dùng nhập vào và chỉ dẫn hệ thống (System Instruction), ngăn chặn mã độc can thiệp vào ràng buộc dị ứng và trường phái.

Điều 8. Quyền của Chủ thể dữ liệu và Kênh tiếp nhận khiếu nại (DPO)

8.1. Các quyền hợp pháp của bạn theo Điều 9 Nghị định 13/2023/NĐ-CP:

- Quyền được biết về hoạt động xử lý dữ liệu của mình;
- Quyền đồng ý hoặc rút lại sự đồng ý đã cấp trước đó;
- Quyền truy cập, xem và tải về bản sao dữ liệu dinh dưỡng cá nhân;
- Quyền yêu cầu chỉnh sửa hoặc cập nhật các chỉ số sức khỏe, trường phái ăn chay và danh sách dị ứng;
- Quyền yêu cầu xóa dữ liệu hoặc hạn chế xử lý dữ liệu cá nhân;
- Quyền khiếu nại, tố cáo hoặc khởi kiện theo quy định của pháp luật.

8.2. Thông tin liên hệ Cán bộ Bảo vệ Dữ liệu (DPO): Mọi yêu cầu trích xuất dữ liệu, rút lại chấp thuận hoặc khiếu nại liên quan đến quyền riêng tư, vui lòng liên hệ trực tiếp Bộ phận DPO:

- Bộ phận Tiếp nhận: Đội ngũ Bảo vệ Dữ liệu Cá nhân (Data Protection Officer - DPO)
- Hòm thư điện tử chuyên trách: privacy@veggielife.vn
- Thời hạn phản hồi cam kết: Tối đa 72 giờ làm việc kể từ thời điểm tiếp nhận văn bản yêu cầu.

ĐẠI DIỆN ĐỘI NGŨ BẢO VỆ DỮ LIỆU (DPO) (Ký duyệt bảo mật thông tin)	CHỦ THỂ DỮ LIỆU (NGƯỜI DÙNG) (Xác nhận đồng thuận tại bước Đăng ký)
VEGGIELIFE DATA COMPLIANCE *Chứng thực tuân thủ NĐ 13/2023/NĐ-CP*	*ĐÃ ĐỒNG THUẬN ĐIỆN TỬ* *Lưu trữ phiên xác thực an toàn*